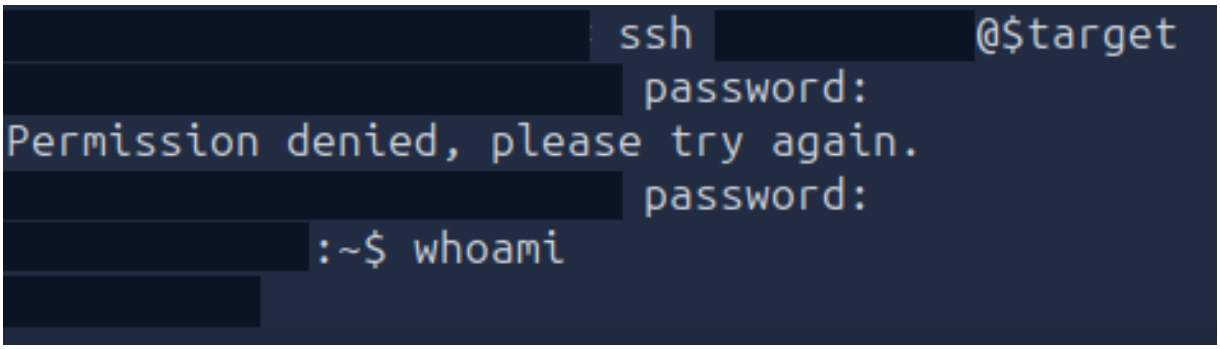
SSHHole | OpenSSH stakeholder brief

KieSec · CVE-2026-123158 · CVSS 3.1 8.1 High · 8 November 2026

Finding

I reproduced an OpenSSH password authentication bypass in an authorized lab environment. A service account intended to have no usable password accepted a specially sized input and opened a remote shell. The affected configuration combines an unpatched OpenSSH server, musl-based Linux such as Alpine, and password login running without PAM, the system's pluggable authentication framework. Alpine advisory



Screenshot from my SSH session.

Business impact

An attacker who can reach an affected SSH service and knows an eligible account name may gain the access that account already has. The vulnerable setup also needs another local account with a compatible password hash. Account access can include application files, backups, or deployment credentials. If the account can elevate without a password, the same foothold can lead to full host control. Wakefield research note · CVE record

Response priorities

1. **Identify exposure.** Start with reachable Alpine and other musl-based systems running OpenSSH. Confirm the installed package revision and whether the effective SSH configuration allows password login without PAM.
2. **Close the path.** Install a vendor-fixed build and restart the SSH daemon. If patching must wait, confirm key-based admin access, then disable SSH password authentication and restart the daemon. Upstream fixed the issue in OpenSSH 10.6p2. Alpine lists fixed builds by release branch.
3. **Verify and investigate.** Test legitimate key-based access in a fresh connection, confirm the bypass path is closed, and review SSH logs for accepted password logins on accounts meant to use keys.

OpenSSH 10.6p2 release notes · Alpine remediation and investigation guidance

Discovery credit. Özgün Kültekin of Wakefield found and reported the vulnerability. I used his research to interpret my lab result. Researcher profile · Original SSHHole disclosure